

OWASP JUICE SHOP

Vulnerability Assessment Report

Generated: March 25, 2026 at 03:05 AM

Target Application	OWASP Juice Shop v17.x
Environment	Ubuntu Linux — localhost:3000
Test Method	Manual Black-Box Penetration Testing
Vulnerabilities Found	5

Setup

```
>sudo apt update && sudo apt upgrade -y
>sudo apt install -y docker.io curl
>sudo systemctl start docker
>sudo docker pull bkimminich/juice-shop
>sudo docker run -d -p 3000:3000 bkimminich/juice-shop
```

1. Executive Summary

This report presents the findings of a manual penetration test conducted against the OWASP Juice Shop — a deliberately vulnerable web application designed for security training. Five vulnerabilities were identified and confirmed, ranging from Critical SQL Injection and Broken Access Control issues to High-severity XSS and Sensitive Data Exposure flaws.

All vulnerabilities were reproduced successfully in a local Ubuntu environment. This report includes the exact payloads used, affected endpoints, potential business impact, and actionable remediation recommendations.

Risk Level	Count
CRITICAL	2
HIGH	3
MEDIUM	0
LOW	0

2. Vulnerability Summary

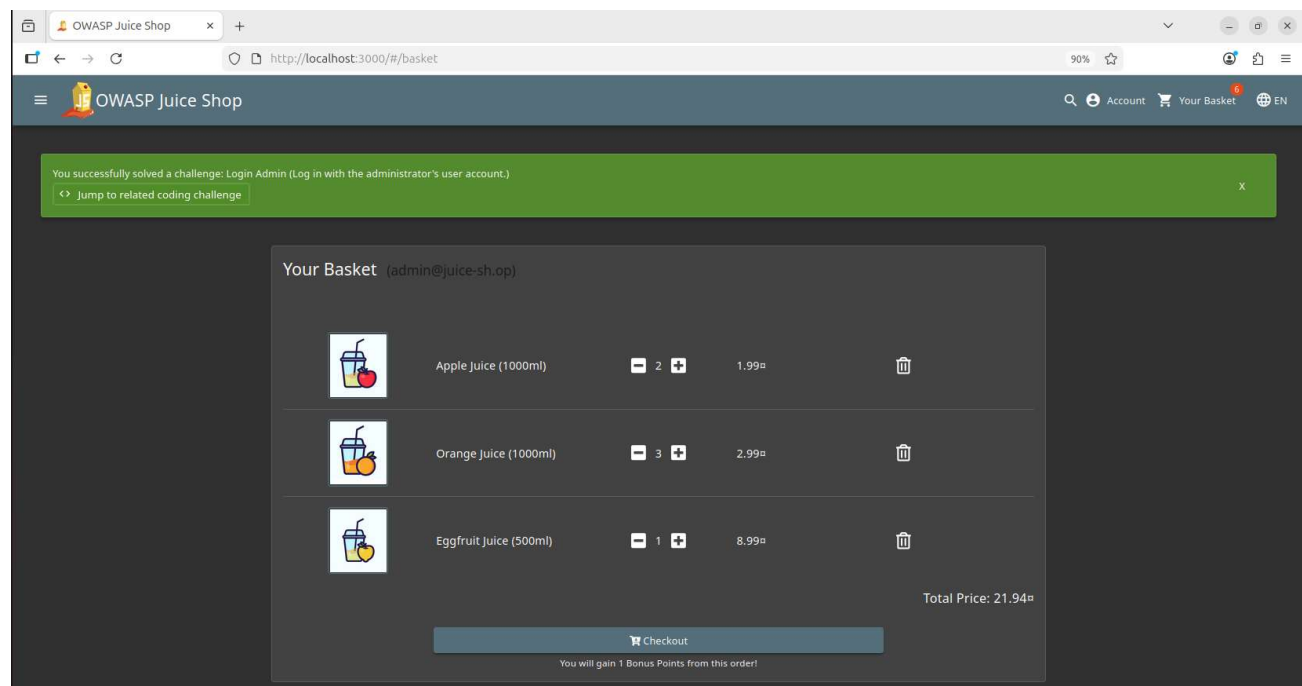
#	Vulnerability	OWASP Category	Severity	Date Tested
01	SQL Injection — Login Bypass	A03:2021 – Injection	CRITICAL	March 25, 2026
02	Reflected Cross-Site Scripting (XSS) — Search Field	A03:2021 – Injection (XSS)	HIGH	March 25, 2026
03	Broken Access Control — Exposed Admin Panel	A01:2021 – Broken Access Control	CRITICAL	March 25, 2026
04	Sensitive Data Exposure — Unprotected API Endpoints	A02:2021 – Cryptographic Failures / Sensitive Data Exposure	HIGH	March 25, 2026
05	Insecure Direct Object Reference (IDOR) — User Basket Access	A01:2021 – Broken Access Control	HIGH	March 25, 2026

3. Detailed Findings

01. SQL Injection — Login Bypass

Severity: **CRITICAL**

Vulnerability	SQL Injection — Login Bypass
OWASP Category	A03:2021 – Injection
Location	http://localhost:3000/#/login (Email field)
Severity	CRITICAL
Payload / Method	' OR 1=1-- (in Email field), any value in Password

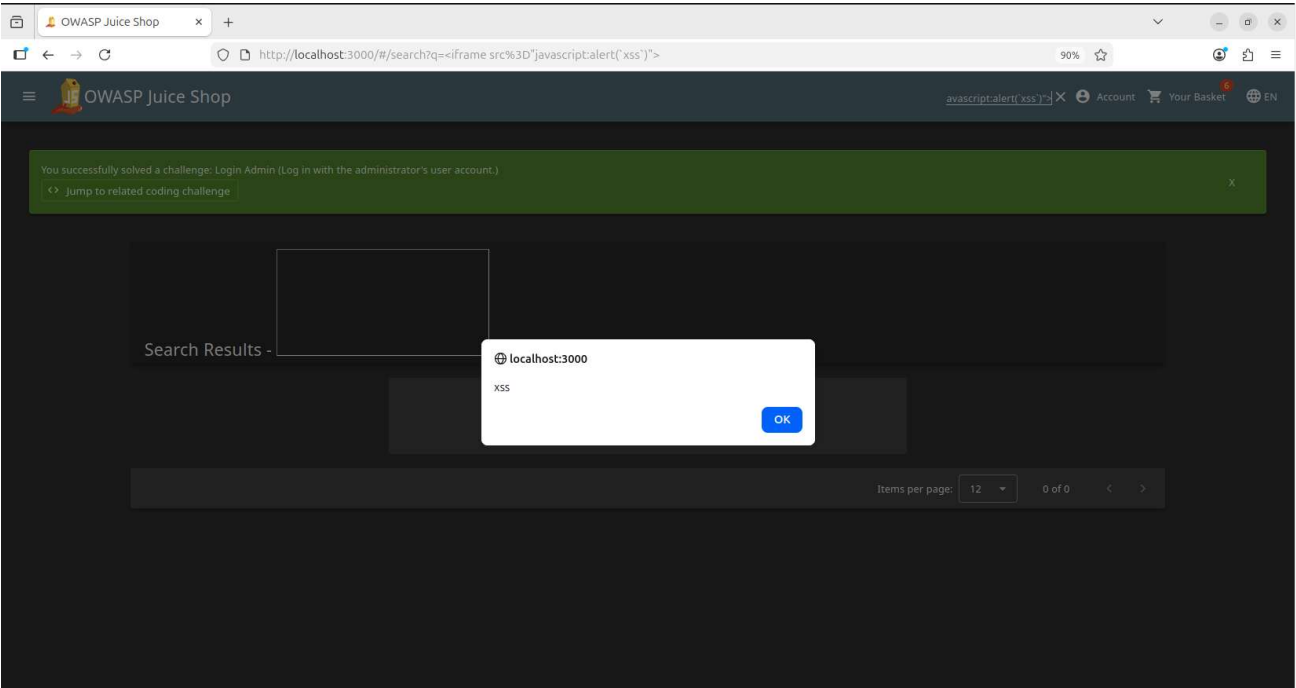


Timestamp: 2026-03-25 02:38:38

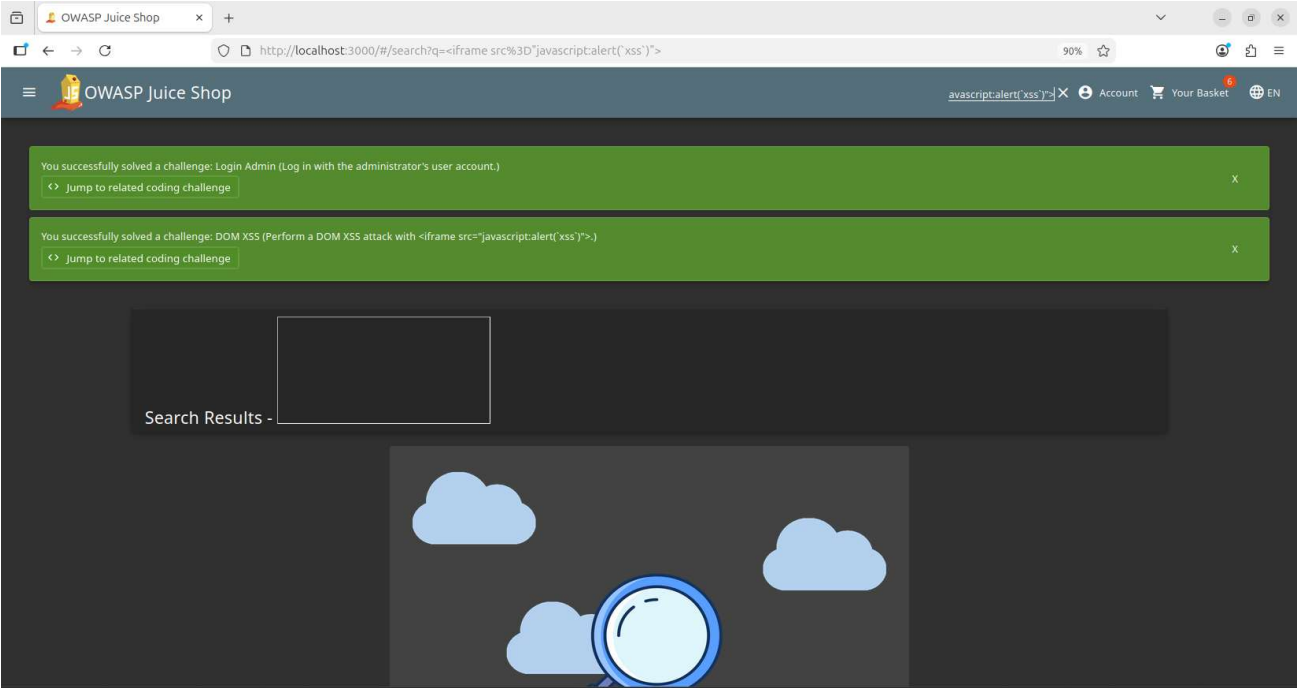
02. Reflected Cross-Site Scripting (XSS) — Search Field

Severity: **HIGH**

Vulnerability	Reflected Cross-Site Scripting (XSS) — Search Field
OWASP Category	A03:2021 – Injection (XSS)
Location	http://localhost:3000 (Search bar)
Severity	HIGH
Payload / Method	<iframe src="javascript:alert(`xss`)">



Timestamp: 2026-03-25 02:40:38

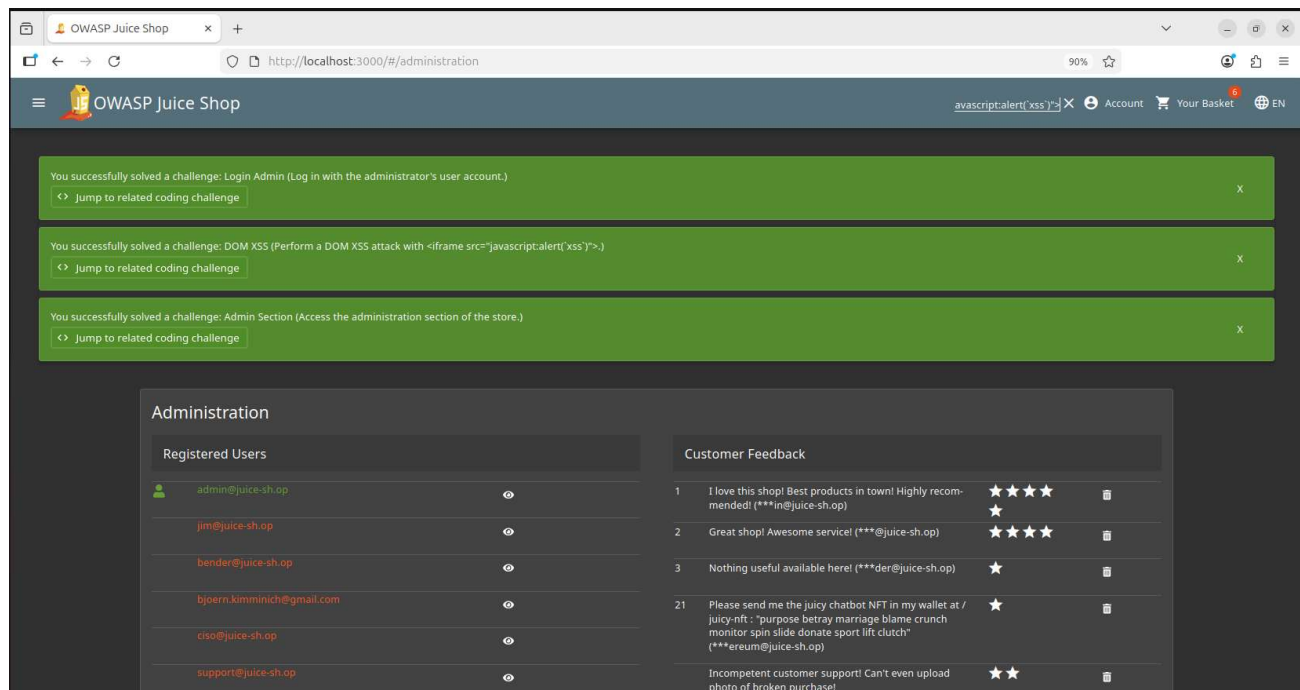


Timestamp: 2026-03-25 02:40:56

03. Broken Access Control — Exposed Admin Panel

Severity: **CRITICAL**

Vulnerability	Broken Access Control — Exposed Admin Panel
OWASP Category	A01:2021 – Broken Access Control
Location	http://localhost:3000/#/administration
Severity	CRITICAL
Payload / Method	Direct URL navigation to #/administration (no privilege check enforced)

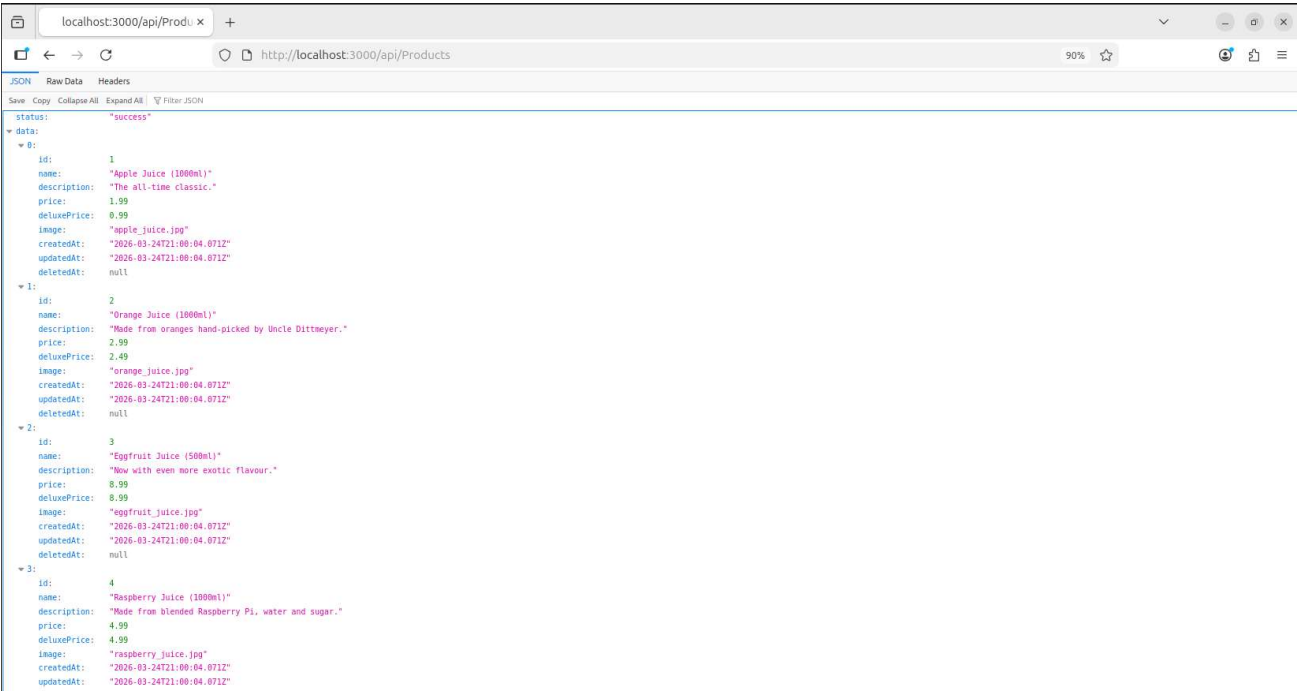


Timestamp: 2026-03-25 02:40:56

04. Sensitive Data Exposure — Unprotected API Endpoints

Severity: **HIGH**

Vulnerability	Sensitive Data Exposure — Unprotected API Endpoints
OWASP Category	A02:2021 – Cryptographic Failures / Sensitive Data Exposure
Location	http://localhost:3000/api/Users, /api/Products, /rest/products/search
Severity	HIGH
Payload / Method	curl http://localhost:3000/api/Products (with Bearer token) or direct url access.



Timestamp: 2026-03-25 02:50:04

[illegible]

Timestamp: 2026-03-25 02:52:37

Severity: HIGH

Vulnerability	Insecure Direct Object Reference (IDOR) — User Basket Access
OWASP Category	A01:2021 – Broken Access Control
Location	http://localhost:3000/rest/basket/{id}
Severity	HIGH
Payload / Method	curl http://localhost:3000/rest/basket/1, /rest/basket/2, /rest/basket/3 (with Bearer token)

[illegible]

Timestamp: 2026-03-25 03:01:03